

M201:

S'initier aux fondamentaux de la Cybersécurité

PARTIE 1 : Identifier la terminologie liée à la Cybersécurité

CHAPITRE 1 : Définir la Cybersécurité

Cybersécurité : est la pratique visant à protéger les systèmes et données sensibles contre les attaques numériques internes ou externes.

Elle est essentielle pour éviter le vol, la perte ou la fraude de données, protégeant ainsi les entreprises

Vulnérabilité : est une faiblesse d'un bien liée à sa conception, réalisation, installation, configuration ou utilisation.

Menace : est la cause potentielle d'un incident pouvant causer des dommages si elle se concrétise.

Menaces courantes : Phishing - Ransomware - Déni de service distribué (DDoS) - Malwares - Homme du milieu (MitM) - Ingénierie sociale - Fraude interne - Menaces persistantes évoluées (APT)

Attaque : est un acte malveillant exploitant une vulnérabilité pour porter atteinte à un bien, concrétisant une menace

CHAPITRE 2

La défense en profondeur : est une stratégie de cybersécurité qui superpose plusieurs mécanismes de protection pour sécuriser les données : si l'un échoue, un autre intervient immédiatement.

Blue Team : est un groupe de consultants experts en réponse aux incidents, qui conseillent sur les améliorations pour prévenir les cyberattaques. Ils assistent l'équipe de sécurité informatique chargée de protéger le réseau interne contre les menaces.

Posture offensive : est une approche proactive pour protéger les systèmes informatiques, les réseaux et les individus contre les attaques. La posture offensive consiste à attaquer son propre système pour en découvrir les points faibles et y apporter des solutions.

Le 3 principaux types de hackers : white hat – black hat – grey hat

Exemple d'activités de simulation d'attaque :

- **Test d'intrusion** : tentative d'accès au système via des techniques réelles de cyberadversaires.
- **Ingénierie sociale** : manipulation des collaborateurs pour obtenir ou créer des identifiants réseau.
- **Interception des communications** : cartographier le réseau et contourner les protections.

- **Clonage de cartes d'accès** : obtenir l'accès aux zones restreintes.

Red Team : est une équipe offensive qui simule les cyberattaques pour identifier et exploiter les failles des défenses de l'entreprise, en utilisant des techniques avancées. Elle est composée de professionnels expérimentés ou de hackers éthiques réalisant des tests d'intrusion réalistes.

Enjeux d'une politique de sécurité des SI

Il s'agit d'un ensemble de lois, de règles et de procédures qu'une entreprise ou une organisation met en place pour : **Protéger ses informations et ses systèmes / Garantir la continuité des services / Se protéger des cyberattaques.**

Les enjeux principaux :

1.  **Protéger les données sensibles** : Les informations comme les données des clients, des employés, ou les informations internes doivent rester confidentielles et sécurisées.
2.  **Éviter les pertes financières** : Les cyberattaques (comme les ransomwares) peuvent entraîner de lourdes pertes : arrêt du service, paiement de rançons, dédommagements...
3.  **Respecter les lois et les réglementations** : Des lois comme le **RGPD** imposent la protection des données personnelles. Si l'entreprise ne les respecte pas, elle peut être lourdement sanctionnée.
4.  **Préserver la réputation de l'entreprise** : Une fuite de données ou un service indisponible peut entraîner une perte de confiance des clients et des partenaires.
5.  **Assurer la continuité de l'activité** : Même en cas de cyberattaque ou de panne, l'entreprise doit avoir un plan d'urgence pour continuer son activité.
5.  **Assurer la continuité de l'activité** : Même en cas de cyberattaque ou de panne, l'entreprise doit avoir un plan d'urgence pour continuer son activité.

Résumé simple :

Une politique de sécurité informatique protège l'organisation, évite les pertes et garantit la continuité de ses services tout en préservant sa réputation.

PARTIE 2

CHAPITRE 1

 **ISO 27001** → Norme certifiable qui définit les exigences pour mettre en place un système de management de la sécurité de l'information (SMSI). Elle sert à gérer les risques et protéger les informations.

☑ **ISO 27002** → Fournit des bonnes pratiques et des recommandations concrètes pour appliquer les contrôles de sécurité mentionnés dans ISO 27001.

☑ **ISO 27005** → Se concentre sur la gestion des risques liés à la sécurité de l'information, en donnant des méthodes pour identifier, évaluer et traiter ces risques.

CHAPITRE 2

Présentation des standards de gestion de vulnérabilités

 Nom	 Description
CVE	Identifiants uniques pour les vulnérabilités connues (ex. CVE-2024-12345).
CWE	Liste des types de faiblesses (ex. injection, débordement mémoire).
CVSS	Score de gravité des failles (0 à 10), indique l'urgence de traitement.
NIST NVD	Base US officielle qui enrichit les CVE avec des détails, scores, solutions.
Exploit-DB	Base d'exploits publics pour démontrer comment exploiter des failles.

☑ **OWASP (Open Web Application Security Project)** →

Organisation mondiale à but non lucratif qui a pour mission de **définir des standards, des outils et des bonnes pratiques pour améliorer la sécurité des applications web.**

Elle est surtout connue pour le **OWASP Top 10**, qui classe les principales vulnérabilités web rencontrées dans le monde.

- L'injection
- Le piratage de session
- L'exposition de données sensibles
- Les entités externes XML (XXE)
- Le contournement des contrôles d'accès
- Security misconfiguration ou mauvaise configuration de sécurité
- Cross-Site Scripting (XSS) ou failles XSS
- La désérialisation non sécurisée
- L'utilisation de composants présentant des vulnérabilités connus
- Le manque de surveillance et de monitoring

CHAPITRE 3 :

☑ **RGPD (Europe)** → Il s'agit d'une loi européenne qui protège les données personnelles. Elle oblige les entreprises à demander l'autorisation, à protéger les informations et à donner aux personnes le contrôle de leurs données. Tout manquement à cette obligation peut entraîner une lourde amende.

☑ **Loi 09-08 (Maroc)** → Loi marocaine sur la **protection des données personnelles**, encadrée par la **CNDP**, garantit les droits d'accès, rectification, opposition, et impose déclaration/autorisation pour certains traitements.

PARTIE 3 : Définir des critères de la Cybersécurité

Critères fondamentaux (D.I.C.)

Le modèle D.I.C. repose sur trois piliers essentiels pour assurer la sécurité d'un système d'information :

☑ **Disponibilité :**

Garantir que les systèmes et les données soient accessibles au moment voulu par les utilisateurs autorisés.

→ Moyens : clustering, redondance, sauvegardes, plans de continuité.

☑ **Confidentialité :**

Assurer que seules les personnes autorisées peuvent accéder aux informations sensibles.

→ Moyens : chiffrement des données, contrôle d'accès physique et logique, gestion des identifiants.

☑ **Intégrité :**

Préserver l'exactitude et la complétude des données, en empêchant toute modification non autorisée.

→ Moyens : hachage, signatures numériques, contrôles des changements, audit des configurations.

PARTIE 4 : Découvrir les métiers de la Cybersécurité

CHAPITRE 1 : Identifier les domaines de la Cybersécurité

1 Sécurité du développement

- Objectif : protéger les applications contre les vulnérabilités.
- Outils : SAST (analyse statique), DAST (analyse dynamique).
- Points clés : authentification, contrôle d'accès, confidentialité, non-répudiation, intégrité.

2 Gouvernance

- Objectif : aligner la cybersécurité sur la stratégie de l'entreprise.
- Norme clé : ISO/IEC 27014.

- Activités : politiques, gestion des risques, formation, suivi, sécurité des fournisseurs.

3 Gestion des risques

- Objectif : identifier, hiérarchiser, traiter les risques.

- Méthodes : EBIOS, MEHARI, OCTAVE.

- Étapes : analyse, seuils, mesures techniques et organisationnelles.

4 Sécurité physique

- Objectif : protéger les infrastructures contre menaces physiques.

- Moyens : contrôle d'accès, surveillance, tests physiques, protections spécifiques (USB, prises réseau).

CHAPITRE 2 : Découvrir le référentiel métier de l'ANSSI

✓ 1 Analyste SOC (Security Operations Center)

- Surveille les systèmes via des outils comme le SIEM, les sondes, les honeypots.
- Analyse les alertes, corrige les vulnérabilités, répond aux incidents.
- Compétences requises :
 - Maîtrise des techniques d'intrusion.
 - Connaissance des règles de sécurité des SI.
 - Autonomie, rigueur, capacité d'analyse et de synthèse.
 - Bonnes qualités rédactionnelles et de communication.

✓ 2 Pentester (Testeur d'intrusion)

- Effectue des tests d'intrusion pour détecter les failles exploitables.
- Simule des attaques réelles pour évaluer les défenses.
- Compétences requises :
 - Connaissance en programmation et en sécurité.
 - Analyse numérique et informatique légale.
 - Compréhension des impacts organisationnels des violations.
 - Capacité à planifier, exécuter et rendre compte des tests.